2026

DOCUMENTATION MAQUETTE CLOUD

DOCUMENT DE REFERENCE

Société TALBAGO

Version 1.0 | Classification : CONFIDENTIEL

13/03/2026

FICHE D'IDENTITÉ DU DOCUMENT

Champ	Valeur
Organisation	TALBAGO
Titre du document	Documentation Maquette Cloud – Scénario d'attaque
Reference	TALBAGO-DMC-2026-v1.0
Version	1.0
Date de création	Mars 2026
Prochaine révision	Mars 2026
Propriétaire	Responsable de la Sécurité des SI (RSSI)
Classification	CONFIDENTIEL — Usage interne
Statut	Approuvé
Périmètre	Environnement AWS CloudGoat – Simulation d'attaque cloud

Tableau d'approbation

Rôle	Nom	Fonction	Date	Visa
Auteur	HANAI Zakaria	Consultant sécurité	Mars 2025	
Reviseur		DSI	Mars 2025	
Approbateur		Direction Générale	Mars 2025	

Historique des révisions

Version	Date	Auteur	Nature des modifications
1.0	Mars 2025	RSSI TALBAGO	Création initiale du document

Ce document est la propriété exclusive de TALBAGO. Toute reproduction ou diffusion non autorisée est strictement interdite

TABLE DES MATIÈRES

Avant-propos *4*

1. Présentation générale de la maquette *5*

1.1 Caractéristiques du scénario **5**

1.2 Ressources AWS déployées **5**

1.3 Contexte de la maquette dans le projet **5**

2. Architecture de la maquette *6*

2.1 Description de l'architecture déployée **6**

2.1 Prérequis techniques **6**

2.2 Procédure de déploiement **7**

Étape 1 – Configuration de l'environnement AWS 7

Étape 2 – Déploiement de l'infrastructure via Terraform 7

Étape 3 – Configuration des profils d'attaque 7

Étape 4 – Destruction de l'environnement 7

2.3 Architecture de l'infrastructure déployée **7**

2.4 Flux de données sensibles et points d'exposition **8**

3. Scénarios d'attaque *9*

3.1 Route A – IAM User « Lara » (voie applicative – RCE) **9**

3.2 Route B – IAM User « McDuck » (voie SSH) **10**

4. Cartographie MITRE ATT&CK for Cloud *11*

5. Analyse de risques *12*

5.1 Synthèse des résultats **12**

5.2 Grille de lecture **12**

6. Contrôles de sécurité recommandés *13*

7. Modèle de responsabilité partagée *14*

8. Liens avec les référentiels de conformité *15*

9. Recommandations et conclusion *16*

9.1 Synthèse des actions prioritaires **16**

9.2 Conclusion **16**

Ce document est la propriété exclusive de TALBAGO. Toute reproduction ou diffusion non autorisée est strictement interdite

Avant-propos

La présente documentation décrit la maquette technique déployée dans le cadre de la mission d'accompagnement en cybersécurité Cloud confiée à notre équipe par la société TALBAGO, conformément aux exigences du CCTP (référence TALBAGO-DSI-SEC-CLOUD-2026-01).

Ce document constitue le livrable « Documentation de la maquette Cloud et du scénario d'attaque » tel que défini à la section Livrables attendus du CCTP. Il décrit l'environnement AWS de simulation déployée, les scénarios d'attaque mis en œuvre, l'analyse de risques associée et les contrôles de sécurité recommandés.

.

> *La sécurité d'un environnement cloud ne s'obtient pas par défaut. Elle résulte de choix de configuration délibérés, de contrôles mis en place dès la conception, et d'une gouvernance continue. Cette maquette en est la démonstration.*

Ce document est la propriété exclusive de TALBAGO. Toute reproduction ou diffusion non autorisée est strictement interdite

1. Présentation générale de la maquette

1.1 Caractéristiques du scénario

Paramètre	Valeur
Nom du scénario	rce_web_app
Difficulté	Hard
Taille	Medium
Fournisseur Cloud	AWS (Amazon Web Services)
Objectif attaquant	Extraire un secret stocké dans une base RDS
Routes d'attaque	2 routes principales (Lara – voie applicative / McDuck – voie SSH)
Conformité illustrée	RGPD Art. 32-33 (violation de données personnelles)
Référentiel d'analyse	MITRE ATT&CK for Cloud

1.2 Ressources AWS déployées

Ressource AWS	Quantité	Rôle dans le scénario
VPC (réseau privé virtuel)	1	Réseau isolé hébergeant l'ensemble de l'infrastructure
ELB – Elastic Load Balancer	1	Point d'entrée public – expose l'application web et génère des logs
EC2 – Instance serveur	1	Héberge l'application web vulnérable (RCE)
S3 – Buckets de stockage	3	Logs ELB / Clés SSH exposées / Credentials RDS en clair
RDS – Base de données	1	Contient le secret à exfiltrer (données clients sensibles)
IAM Users	2	Lara (route applicative) et McDuck (route S3/SSH)

1.3 Contexte de la maquette dans le projet

Ce que la maquette illustre dans le cadre du PFE

La maquette Cloud constitue l'un des livrables contractuels de la mission, tel que défini à la section « Réalisation d'une maquette Cloud et démonstration des mesures de sécurité » du CCTP.

Elle a pour objectif d'illustrer concrètement les risques liés à une configuration cloud non sécurisée et de démontrer l'efficacité des mesures de sécurité recommandées dans le cadre de cette mission. Elle ne constitue pas une mise en production : il s'agit d'un environnement de démonstration à destination des équipes de TALBAGO.

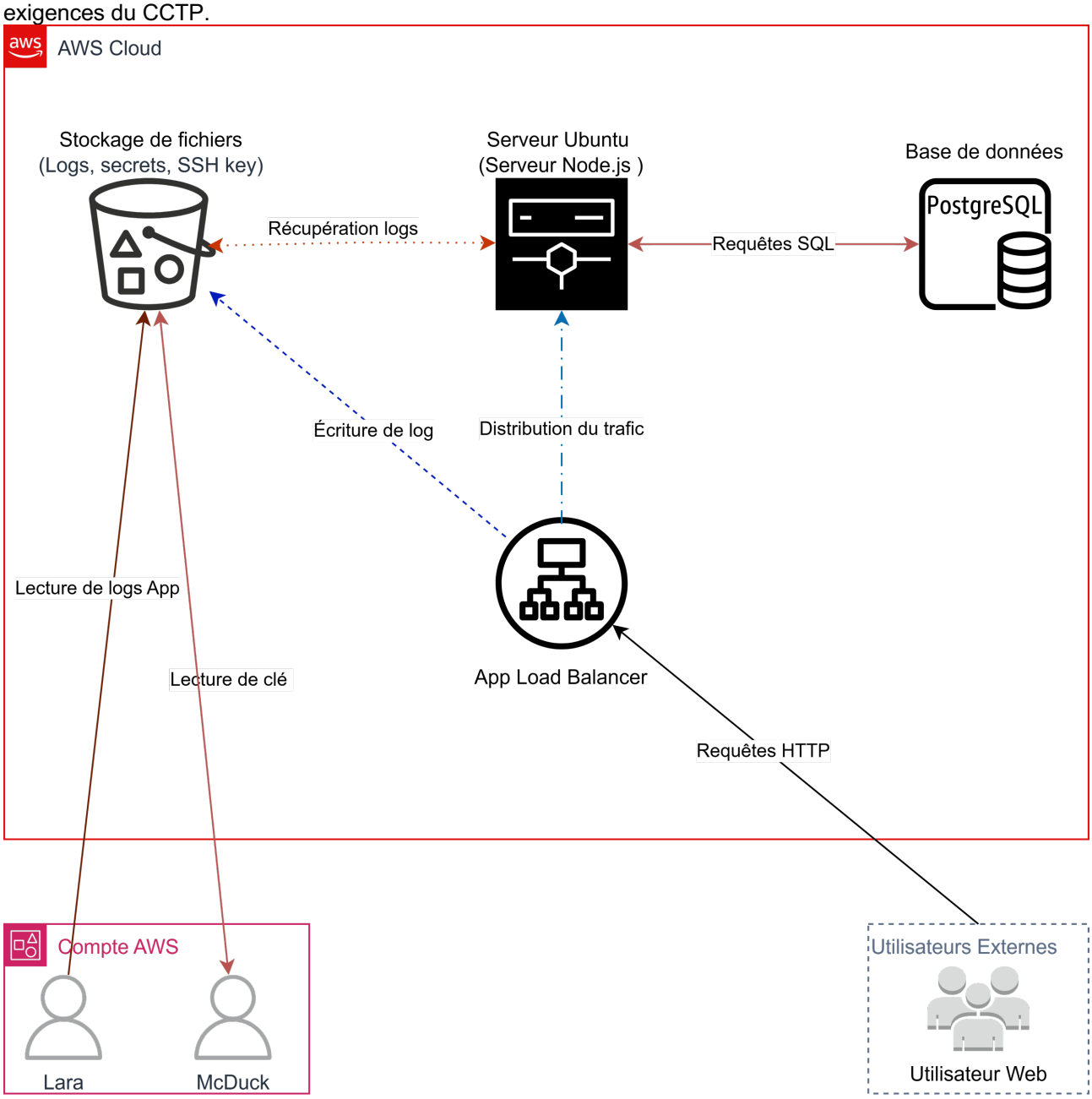
Elle s'inscrit en cohérence avec les autres livrables de la mission — stratégie de sécurité, politique de sécurité cloud, Plan d'Assurance Sécurité — dont elle illustre les préconisations de manière technique et concrète.

Ce document est la propriété exclusive de TALBAGO. Toute reproduction ou diffusion non autorisée est strictement interdite

2. Architecture de la maquette

2.1 Description de l'architecture déployée

Cette section décrit l'infrastructure déployée, les outils utilisés et les procédures permettant aux équipes de TALBAGO de reproduire ou redéployer la maquette dans un environnement équivalent, conformément aux exigences du CCTP.



2.1 Prérequis techniques

Outil	Version minimale	Rôle
Python	3.6+	Exécution du script de déploiement CloudGoat
Terraform	0.12+	Déploiement de l'infrastructure AWS (IaC)
AWS CLI	2.x	Interaction avec les services AWS
Compte AWS	Droits AdministratorAccess	Création et destruction des ressources

Ce document est la propriété exclusive de TALBAGO. Toute reproduction ou diffusion non autorisée est strictement interdite

Outil	Version minimale	Rôle
OS	Linux	Windows non supporté officiellement

2.2 Procédure de déploiement

Étape 1 – Configuration de l'environnement AWS

Créer un utilisateur IAM dédié avec les droits AdministratorAccess et configurer le profil AWS CLI :

```
aws configure --profile cloudgoat
```

Configurer la liste blanche d'adresses IP autorisées à accéder à l'environnement :

```
./cloudgoat.py config whitelist --auto
```

Étape 2 – Déploiement de l'infrastructure via Terraform

La commande suivante déclenche le déploiement Terraform de l'ensemble des ressources AWS (VPC, EC2, ELB, S3, RDS, IAM) :

```
./cloudgoat.py create rce_web_app --profile cloudgoat
```

À l'issue du déploiement, deux paires de credentials IAM sont générées : une pour l'utilisateur Lara, une pour l'utilisateur McDuck. Ces credentials servent de points de départ aux deux routes d'attaque.

Étape 3 – Configuration des profils d'attaque

Configurer les profils AWS CLI pour chaque utilisateur attaquant :

```
aws configure --profile Lara
aws configure --profile McDuck
```

Étape 4 – Destruction de l'environnement

Une fois la démonstration terminée, détruire l'ensemble des ressources pour éviter tout coût AWS résiduel :

```
./cloudgoat.py destroy rce_web_app --profile cloudgoat
```

2.3 Architecture de l'infrastructure déployée

L'infrastructure reproduit un environnement AWS typique d'une organisation ayant migré une application web vers le cloud public :

- Un VPC privé segmente les ressources et isole l'infrastructure du réseau public
- L'ELB expose publiquement l'application web hébergée sur l'instance EC2 et stocke ses logs dans un bucket S3

Ce document est la propriété exclusive de TALBAGO. Toute reproduction ou diffusion non autorisée est strictement interdite

- Trois buckets S3 sont configurés avec des niveaux d'accès différents : logs ELB (accessible à Lara), clés SSH (accessible à McDuck), credentials RDS (accessible uniquement via le rôle EC2)
- La base RDS PostgreSQL est en subnet privé, accessible uniquement depuis l'instance EC2
- Les deux comptes IAM (Lara et McDuck) ont des permissions délibérément limitées mais suffisantes pour initier chaque route d'attaque

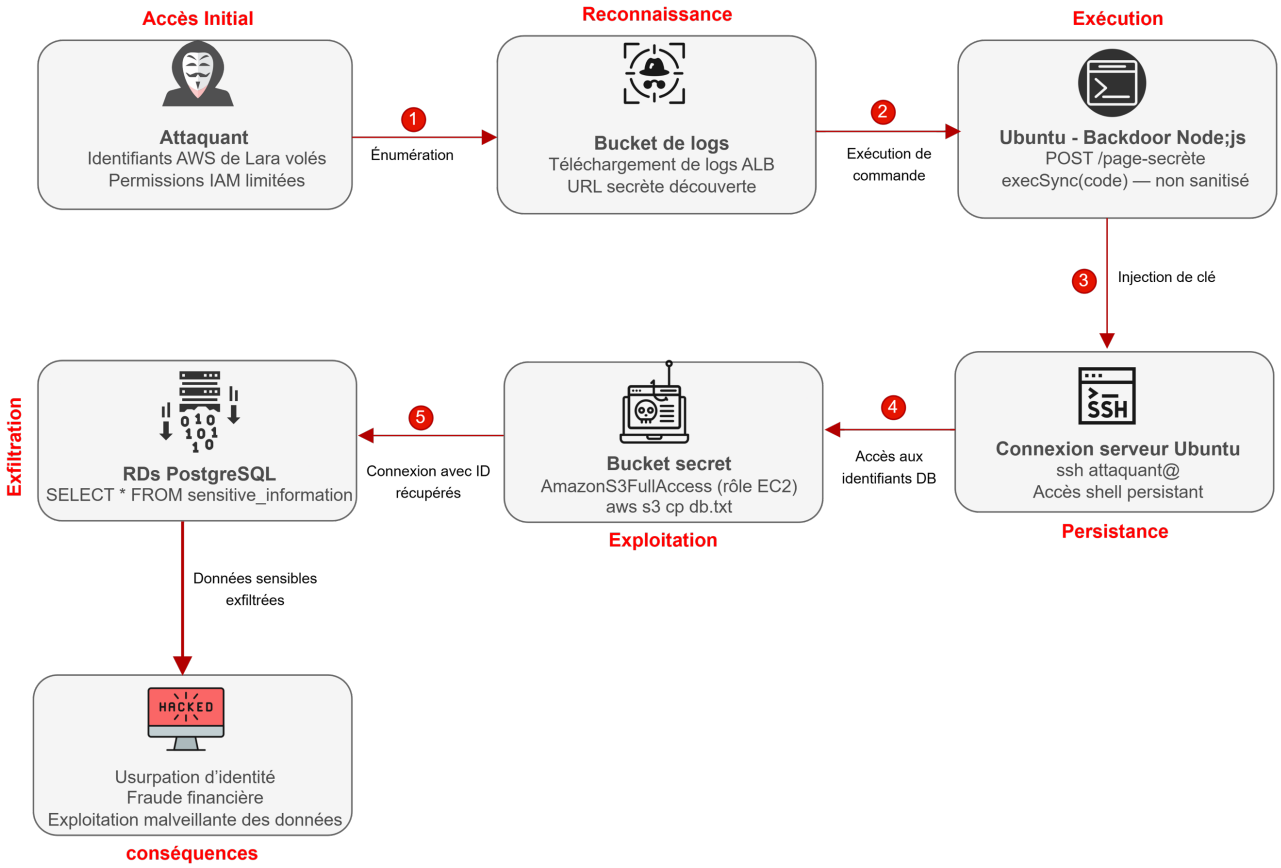
2.4 Flux de données sensibles et points d'exposition

Source	Destination	Donnée exposée	Nature du risque
Bucket S3 – logs ELB	Attaquant (route Lara)	URL d'administration secrète	Divulgation d'informations
Bucket S3 – public	Attaquant (route McDuck)	Paire de clés SSH	Accès non autorisé à EC2
EC2 Metadata (IMDS v1)	Attaquant (via EC2)	Credentials RDS	Élévation de privilèges
Bucket S3 – privé	Attaquant (via rôle EC2)	Credentials RDS (fichier db.txt)	Exfiltration de données
Base RDS PostgreSQL	Attaquant	Table sensitive_information	Violation RGPD Art. 32-33

Ce document est la propriété exclusive de TALBAGO. Toute reproduction ou diffusion non autorisée est strictement interdite

3. Scénarios d'attaque

Deux routes d'exploitation distinctes ont été identifiées et mises en œuvre. Chacune exploite des erreurs de configuration différentes mais converge vers le même objectif : l'extraction du secret contenu dans la base RDS, illustrant une violation des données personnelles au sens du RGPD.



3.1 Route A – IAM User « Lara » (voie applicative – RCE)

Vulnérabilité principale exploitée

Cette route repose sur une vulnérabilité applicative de type Remote Code Execution (RCE) combinée à une mauvaise configuration des logs ELB (accessibles publiquement) et à des permissions IAM trop larges accordées au rôle de l'instance EC2.

Étape	Action de l'attaquant	Composant ciblé	Technique MITRE
1	Exploration de l'environnement AWS avec les credentials Lara	IAM / ELB	T1580
2	Listage des buckets S3 – découverte du bucket de logs ELB	S3	T1619
3	Analyse des logs ELB – identification de l'URL admin secrète	S3 / ELB logs	T1619
4	Visite de l'URL admin – identification de la vulnérabilité RCE	EC2 / App web	T1190
5	Exploitation RCE – obtention d'un accès shell sur l'EC2	EC2	T1059

Ce document est la propriété exclusive de TALBAGO. Toute reproduction ou diffusion non autorisée est strictement interdite

Étape	Action de l'attaquant	Composant ciblé	Technique MITRE
6a	Via EC2 : accès au bucket S3 privé contenant les credentials RDS	S3 / RDS	T1530
6b	Via IMDS EC2 : récupération directe des credentials RDS	EC2 Metadata	T1528
7	Connexion à RDS et extraction du secret	RDS	T1567

3.2 Route B – IAM User « McDuck » (voie SSH)

Vulnérabilité principale exploitée

Cette route exploite un bucket S3 mal configuré exposant une paire de clés SSH, permettant un accès direct à l'instance EC2 sans passer par l'application web. Elle illustre le risque de stockage de secrets dans des ressources cloud insuffisamment protégées.

Étape	Action de l'attaquant	Composant ciblé	Technique MITRE
1	Exploration AWS avec les credentials McDuck – listage des buckets S3	IAM / S3	T1619
2	Accès au bucket accessible – récupération d'une paire de clés SSH	S3	T1552.005
3	Listage des instances EC2 – identification du serveur cible	EC2	T1580
4	Connexion SSH à EC2 avec les clés récupérées	EC2	T1078.004
5	Pivot via le rôle IAM de l'instance – accès au bucket S3 privé	IAM / S3	T1550
6	Récupération du fichier contenant les credentials RDS	S3	T1530
7	Connexion à RDS et extraction du secret	RDS	T1567

Ce document est la propriété exclusive de TALBAGO. Toute reproduction ou diffusion non autorisée est strictement interdite

4. Cartographie MITRE ATT&CK for Cloud

Le framework MITRE ATT&CK for Cloud permet de formaliser chaque étape des attaques selon une taxonomie reconnue par la communauté SSI internationale. Cette cartographie est indispensable pour dépasser la simple démonstration technique et inscrire la maquette dans un cadre d'analyse formalisé.

Tactique	Technique	ID	Application dans le scénario
Reconnaissance	Active Scanning	T1595	Exploration de l'environnement AWS (ELB, S3, EC2, RDS)
Initial Access	Exploit Public-Facing Application	T1190	Exploitation de la vulnérabilité RCE sur l'application web
Initial Access	Valid Accounts – Cloud	T1078.004	Utilisation des credentials IAM (Lara / McDuck)
Execution	Command & Scripting Interpreter	T1059	Exécution de commandes shell via la RCE
Discovery	Cloud Storage Object Discovery	T1619	Listage et accès aux buckets S3
Discovery	Cloud Infrastructure Discovery	T1580	Énumération des instances EC2 et de la base RDS
Credential Access	Unsecured Credentials – Cloud	T1552.005	Clés SSH dans S3 public, credentials RDS en fichier texte
Credential Access	Steal App Access Token (IMDS)	T1528	Récupération des credentials via EC2 Metadata Service
Lateral Movement	Use Alternate Auth Material	T1550	Pivot via le rôle IAM de l'instance EC2
Collection	Data from Cloud Storage	T1530	Extraction de données depuis les buckets S3
Exfiltration	Exfiltration Over Web Service	T1567	Extraction du secret depuis la base RDS

Ce document est la propriété exclusive de TALBAGO. Toute reproduction ou diffusion non autorisée est strictement interdite

5. Analyse de risques

5.1 Synthèse des résultats

L'analyse de risques associe à chaque vulnérabilité identifiée dans la maquette une probabilité d'exploitation réelle et un impact potentiel sur l'organisation, selon la méthode EBIOS RM préconisée par l'ANSSI. Le niveau de risque résultant oriente les priorités de remédiation.

Vulnérabilité identifiée	Probabilité	Impact	Niveau de risque	Référentiel impacté
RCE sur application web exposée	Élevée	Critique	CRITIQUE	NIS2 / DORA
Logs ELB publics exposant URL admin	Élevée	Élevé	ÉLEVÉ	RGPD / NIS2
Clés SSH dans bucket S3 accessible	Élevée	Critique	CRITIQUE	ISO 27001 A.9
Credentials RDS en clair dans fichier	Moyenne	Critique	CRITIQUE	RGPD / PCI DSS
Accès IMDS v1 non restreint	Moyenne	Élevé	ÉLEVÉ	NIS2 / DORA
Permissions IAM trop larges (rôle EC2)	Élevée	Élevé	ÉLEVÉ	ISO 27001 A.9 / NIS2
Absence de chiffrement des données RDS	Faible	Critique	ÉLEVÉ	RGPD Art. 32 / HDS

5.2 Grille de lecture

Probabilité : Faible = exploitation rare dans ce contexte / Moyenne = exploitation possible avec compétences standards / Élevée = exploitation fréquente et documentée dans la littérature SSI.

Impact : Élevé = perturbation significative des opérations ou des données / Critique = perte ou divulgation de données personnelles, arrêt de service ou atteinte à la réputation.

Niveau de risque : CRITIQUE = action corrective immédiate requise / ÉLEVÉ = traitement prioritaire dans le plan de remédiation.

Ce document est la propriété exclusive de TALBAGO. Toute reproduction ou diffusion non autorisée est strictement interdite

6. Contrôles de sécurité recommandés

Pour chaque vulnérabilité identifiée, des contrôles de sécurité natifs AWS et des mesures organisationnelles sont recommandés afin de ramener le risque à un niveau acceptable. Ces contrôles constituent les exigences de sécurité à inclure dans le CCTP lors de l'appel d'offres.

Vulnérabilité	Contrôle technique (AWS)	Contrôle organisationnel	Priorité
RCE – application web	AWS WAF + validation entrées + patch management automatisé	Tests de pénétration réguliers, revue de code sécurisé (SAST/DAST)	P1 – Immédiat
Logs ELB exposés	Bucket S3 privé par défaut, politique d'accès restrictive, S3 Block Public Access	Politique de classification des données, contrôle des ACL S3	P1 – Immédiat
Clés SSH dans S3	AWS Secrets Manager, rotation automatique via Lambda	Processus de gestion des secrets, sensibilisation des développeurs	P1 – Immédiat
Credentials RDS en clair	AWS Secrets Manager + chiffrement KMS des secrets	Interdiction de stocker des secrets en clair, audit de code régulier	P1 – Immédiat
IMDS v1 non restreint	Activation obligatoire d'IMDSv2 (hop limit = 1)	Durcissement des instances EC2 selon CIS Benchmark AWS	P2 – Court terme
Permissions IAM excessives	Principe du moindre privilège, AWS IAM Access Analyzer	Revue trimestrielle des droits IAM, suppression des droits orphelins	P2 – Court terme
RDS non chiffré	Chiffrement at-rest KMS + SSL/TLS obligatoire en transit	Politique de chiffrement pour toutes données à caractère sensible	P2 – Court terme

Ce document est la propriété exclusive de TALBAGO. Toute reproduction ou diffusion non autorisée est strictement interdite

7. Modèle de responsabilité partagée

En environnement AWS, la sécurité repose sur un modèle de responsabilité partagée entre AWS (fournisseur) et le client. La maquette illustre directement ce principe : les vulnérabilités exploitées ne sont pas des failles d'AWS, mais des erreurs de configuration relevant de la responsabilité du client.

Domaine de sécurité	Responsabilité AWS	Responsabilité TALBAGO
Infrastructure physique des datacenters	Assurée – certifications SOC2, ISO 27001	Non applicable
Hyperviseur et réseau physique	Assurée	Non applicable
Système d'exploitation EC2	Non applicable	Patchs OS, durcissement, antivirus
Configuration des buckets S3	Non applicable	Politiques d'accès, chiffrement, versioning
Gestion des identités IAM	Non applicable	Moindre privilège, MFA, rotation des clés
Sécurité de l'application web	Non applicable	Sécurité du code, WAF, tests d'intrusion
Données stockées dans RDS	Infrastructure de la base (disponibilité)	Chiffrement, accès, sauvegardes, conformité
Conformité RGPD / NIS2	Certifications et rapports d'audit tiers	Traitement des données, DPO, registre des activités

Enseignement clé de la maquette

L'ensemble des vulnérabilités exploitées dans les deux routes d'attaque relève exclusivement de la responsabilité de TALBAGO en tant qu'utilisateur du cloud, et non d'AWS. La sécurité physique et l'infrastructure de base sont assurées par AWS. En revanche, la configuration des ressources, la gestion des accès, la protection des données et la sécurité applicative restent entièrement sous la responsabilité de TALBAGO.

TALBAGO ne pouvant pas auditer directement les infrastructures AWS, elle doit s'appuyer sur les rapports d'auditeurs certifiés (SOC 2 Type II, ISO 27001, PCI DSS) pour s'assurer du respect des obligations du fournisseur.

Ce document est la propriété exclusive de TALBAGO. Toute reproduction ou diffusion non autorisée est strictement interdite

8. Liens avec les référentiels de conformité

Les vulnérabilités et contrôles identifiés dans cette maquette s'inscrivent dans le cadre des principaux référentiels de conformité applicables à un environnement cloud. Ce tableau établit le lien entre les constatations techniques de la maquette et les obligations réglementaires de TALBAGO.

Référentiel	Article / Contrôle	Lien avec le scénario
RGPD	Art. 32 – Sécurité du traitement	Données clients exposées via RDS sans chiffrement suffisant ni contrôle d'accès adéquat
RGPD	Art. 33 – Notification de violation	Exfiltration de données → obligation de notification à la CNIL dans les 72 heures
NIS2	Art. 21 – Mesures de gestion des risques	Absence de contrôles sur les accès cloud, les credentials et la sécurité applicative
DORA	Art. 9 – Gestion des risques TIC	Risques liés à la dépendance aux services AWS non encadrés par une politique de sécurité
ISO 27001	A.9 – Contrôle d'accès	Permissions IAM excessives, clés SSH non gérées, absence de rotation des credentials
ISO 27001	A.12 – Sécurité opérationnelle	Absence de patch management sur l'application web ayant conduit à la vulnérabilité RCE
PCI DSS	Req. 6 – Sécurité applicative	Vulnérabilité RCE non corrigée sur une application exposée publiquement
HDS	Critère 5 – Sécurité des données	Données de santé potentiellement exposées via base RDS non chiffrée

Ce document est la propriété exclusive de TALBAGO. Toute reproduction ou diffusion non autorisée est strictement interdite

9. Recommandations et conclusion

9.1 Synthèse des actions prioritaires

Priorité	Action	Échéance recommandée
P1 – Immédiat	Corriger la vulnérabilité RCE (patch applicatif + WAF)	Avant mise en production
P1 – Immédiat	Sécuriser les buckets S3 (Block Public Access + ACL restrictives)	Avant mise en production
P1 – Immédiat	Migrer tous les secrets vers AWS Secrets Manager	Avant mise en production
P1 – Immédiat	Activer IMDSv2 sur toutes les instances EC2	Avant mise en production
P2 – Court terme	Restreindre les permissions IAM au strict nécessaire (least privilege)	J+30
P2 – Court terme	Activer le chiffrement RDS (KMS) et forcer SSL/TLS en transit	J+30
P2 – Court terme	Déployer AWS CloudTrail et GuardDuty pour la détection d'incidents	J+30
P3 – Moyen terme	Réaliser un audit de conformité RGPD/NIS2 complet de l'environnement cloud	J+90
P3 – Moyen terme	Former les équipes développement à la sécurité cloud (AWS Security Best Practices)	J+90

9.2 Conclusion

Cette maquette démontre qu'une infrastructure AWS fonctionnelle peut présenter des risques critiques résultant de simples erreurs de configuration. Les deux routes d'attaque illustrent des vulnérabilités fréquemment rencontrées en environnement réel : exposition involontaire de secrets, permissions IAM trop larges, applications non patchées et absence de surveillance.

Ce travail ne se limite pas à la démonstration technique. Il s'inscrit dans une démarche de gouvernance : les vulnérabilités sont formalisées selon le référentiel MITRE ATT&CK, analysées au travers d'une analyse de risques structurée, et reliées aux obligations réglementaires de TALBAGO (RGPD, NIS2, DORA, ISO 27001).

La mise en œuvre des contrôles identifiés dans ce document permettra de réduire significativement la surface d'attaque de TALBAGO et de répondre aux exigences des référentiels de conformité applicables, constituant ainsi le socle de sécurité attendu avant toute migration en production.

– Fin du document –

Ce document est la propriété exclusive de TALBAGO. Toute reproduction ou diffusion non autorisée est strictement interdite